

PIXELSTORE

Infrastructure cloud AWS sécurisée et automatisée

Jimmy Barbier

Dorian Poncelet

Matthieu Broquard

Contexte & objectifs

PME parisienne - 35 employés - e-commerce smartphones haut de gamme



Disponibilité

Service continu même en cas de panne d'une zone AWS



Sécurité

Données clients protégées, défense en profondeur



Évolutivité

Absorber les pics de trafic sans intervention



Automatisation

Déploiement complet reproductible en une commande

L'infrastructure en chiffres

77

ressources AWS

17

modules Terraform

2

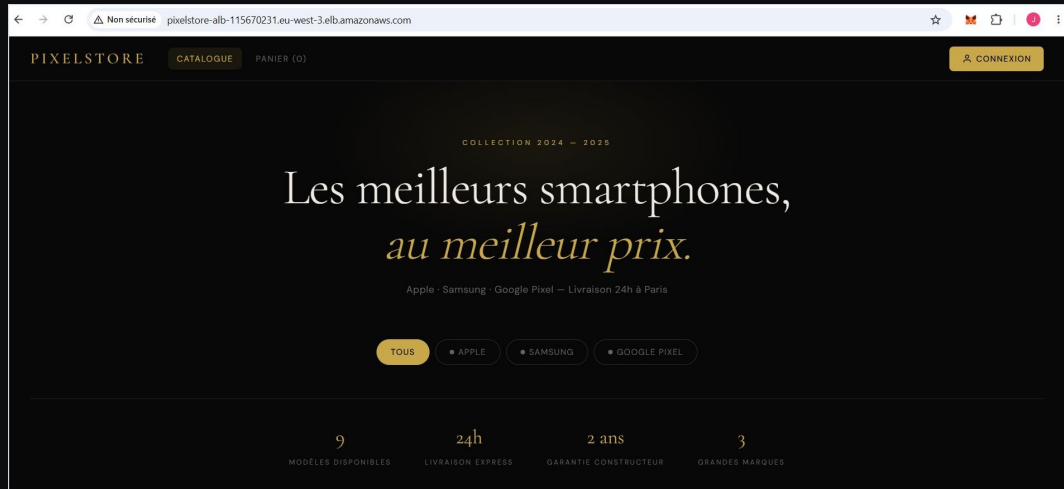
zones de disponibilité

1

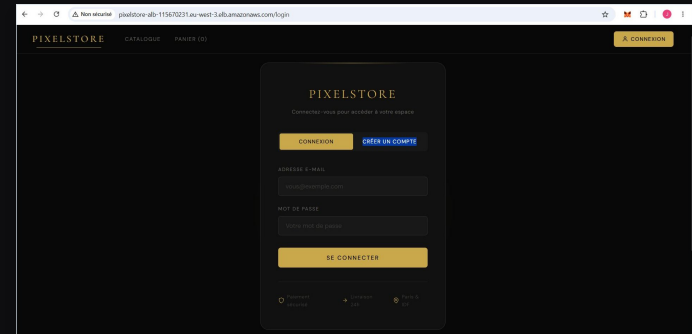
seule commande de déploiement

Le site PixelStore

Application Flask déployée - catalogue, authentification, panier



Page d'accueil - catalogue 9 modèles, 3 marques



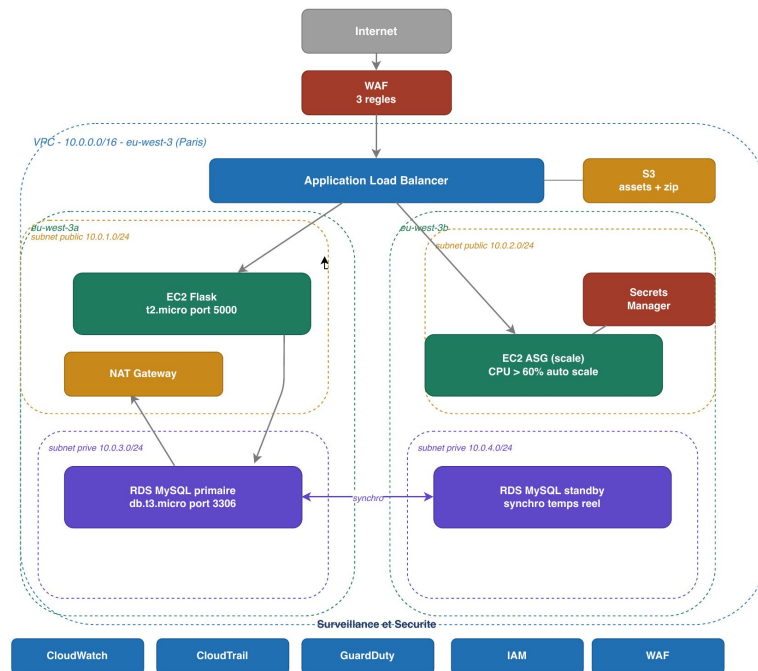
Connexion & inscription

Sessions Flask signées, mots de passe bcrypt

Architecture globale

Jimmy Barbier

VPC Multi-AZ - eu-west-3 (Paris) - conformité RGPD



Défense en profondeur

Jimmy Barbier

Plusieurs couches indépendantes - aucun contrôle unique suffisant



Périmètre - Cloudflare + WAF

TLS/HTTPS termine par Cloudflare en frontal, puis WAF AWS : Common Rule Set (OWASP), SQLi, RateLimit



Réseau - SG & NACL

SG en cascade ALB -> EC2 -> RDS, NACL stateless en complément au niveau subnet



Identité - IAM

Rôle EC2 en moindre privilège, aucune clé stockée, accès via SSM (pas de SSH)



Secrets - Secrets Manager

Credentials RDS jamais en clair, récupérés à l'exécution via le SDK AWS



Détection - GuardDuty

Analyse VPC Flow Logs, DNS et CloudTrail, alertes SNS sur findings



Données - RDS & chiffrement

Multi-AZ synchrone, snapshot complet toutes les 12 h + binlogs/PITR ~15 min, chiffrement AES256 au repos, TLS via Cloudflare en transit

Le WAF en pratique

Jimmy Barbier

TLS assuré par Cloudflare en frontal, WAF AWS en couche complémentaire



3 règles actives sur l'ALB

- Common Rule Set - attaques web courantes (OWASP Top 10)
- SQLi Rule Set - injections SQL
- RateLimit - blocage IP au-delà de 2000 requêtes / 5 min (anti-DDoS)

Résultat du test : payloads canoniques et 4 variantes d'évasion tous bloqués en HTTP 403.



La vraie protection est dans le code

Les requêtes paramétrées PyMySQL neutralisent les injections SQL au niveau applicatif. Un guillemet simple ne produit aucune erreur. Le WAF vient en seconde ligne.

" Un WAF protège uniquement ce qu'il inspecte. Il ne remplace pas un code sécurisé. "

Infrastructure as Code

Jimmy Barbier

Terraform - 17 modules - 77 ressources - un seul terraform apply

Déclaratif

On décrit l'état cible, Terraform calcule comment l'atteindre

Idempotent

Rejouer terraform apply produit le même résultat, sans drift

Versionné

Tout le code est sur GitHub : revue, audit, historique complet

Reproductible

Backend distant S3 + verrou DynamoDB pour le travail en équipe



```
$ terraform apply
Plan: 77 to add, 0 to change, 0 to destroy.
Apply complete! 77 resources added.
-> site opérationnel en 10 à 15 min
```

Couvert par les modules : réseau, sécurité, identité & secrets, compute, données, observabilité, stockage.

Application & haute disponibilité

Matthieu Broquard

Flask + RDS Multi-AZ + Auto Scaling



Application Flask

4 pages (catalogue, détail, panier, authentification). Servie par Gunicorn (serveur de production). Mots de passe bcrypt, credentials via Secrets Manager.



Auto Scaling

Min 1 / Max 2 instances. Une 2e instance se lance automatiquement au-delà de 60% de CPU.



RDS Multi-AZ

Réplique synchrone en eu-west-3b. Bascule automatique en 1 à 2 min en cas de panne.



Reprise (DR)

RPO ~15 min (snapshot toutes les 12 h via AWS Backup + binlogs/PITR ~15 min), RTO ~15 min. Terraform recrée tout depuis le code.

Coûts & FinOps

Matthieu Broquard

AWS vs on-premise - tarification eu-west-3

150 EUR

par mois

1 800 EUR

par an (On-Demand)

~900 EUR

par an avec Savings Plans

Économie première année vs on-premise

plus de 18 000 EUR

- AWS année 1 : 1 800 EUR
- On-premise année 1 : 20 420 EUR (CAPEX 11 600 + OPEX)
- Aucun investissement initial, HA incluse, RGPD (Paris)

Test d'intrusion

Matthieu Broquard

Boîte grise sur la surface web - 8 juin 2026



Méthodologie

- Reconnaissance (nmap, fingerprint Flask/Werkzeug)
- Identification du WAF (403, sqlmap)
- Tests d'injection SQL (connexion, filtre catalogue)
- Analyse authentification & sessions
- Analyse de configuration (en-têtes, cookies, transport)



Ce qui résiste

- Injection SQL neutralisée (requêtes paramétrées) sur connexion et catalogue
- WAF efficace : payloads + 4 évasions bloqués en 403
- Cookie HttpOnly présent (anti-vol XSS)
- Validation côté serveur de la correspondance des mots de passe

8 constats du pentest - tous corrigés

Matthieu Broquard

Toutes les vulnérabilités remédiées dans le code (+ 1 trouvée hors pentest)

ID	Constat	Statut
F1	Chiffrement TLS - HTTPS via Cloudflare + ALB restreint aux IP Cloudflare	Corrigé
F2	Serveur de production Gunicorn (Werkzeug retiré)	Corrigé
F3	En-têtes de sécurité ajoutés (CSP, HSTS, X-Frame-Options, nosniff)	Corrigé
F4	Cookies de session Secure + SameSite + HttpOnly	Corrigé
F5	Énumération de comptes - message d'inscription générique	Corrigé
F6	Identité en cookie - signée par une SECRET_KEY forte	Corrigé
F7	Politique de mot de passe serveur (≥ 12 car. + complexité)	Corrigé
F8	SECRET_KEY forte 64 car. (Secrets Manager) - démarrage refusé sinon	Corrigé

+ Hors pentest

Open Redirect sur `/cart/add` corrigé (redirections internes uniquement).

Durcissements : exécution non-root, CSP stricte, ALB restreint à Cloudflare.

8/8 constats corrigés dans le code poussé sur GitHub.

Axes d'amélioration

Matthieu Broquard

Du laboratoire vers la production



TLS de bout en bout

Chiffrer aussi Cloudflare -> ALB (certificat d'origine, Full Strict)



Gouvernance & procédures

Réponse à incident (RS) & reprise (RC), registre RGPD Art.30, NDA



MFA sur le compte AWS

Authentification multi-facteurs sur les accès console



Annuaire centralise

Intégration Samba AD / AWS Managed Microsoft AD pour les identités



Pipeline CI/CD

Scan IaC (Checkov, tfsec) et déploiement automatisé



RPO réduit

Réplication RDS multi-région, snapshots S3 cross-region

Analyse GRC

Dorian Poncelet

Gouvernance, Risques & Conformité - 3 référentiels croisés



ISO 27001:2022

Gap analysis - 93 contrôles évalués



NIST CSF 2.0

Maturité par fonction - 77 sous-catégories



FAIR

Risque chiffré - Monte Carlo 10 000 itérations

Referentiel	Score actuel	Cible	Verdict
ISO 27001:2022	1,72 / 5 (28%)	4,0 / 5	Programme 12-18 mois
NIST CSF 2.0	Tier 1 (0,69 / 4)	Tier 3	Actions immédiates RS/RC
FAIR (ALE/an)	192k -> ~17k EUR	< 30 000 EUR	F1+F8 corrigés : -175 k€/an
RGPD	Non conforme Art.30	Registre + DPO	Registre à créer

Base technique solide ; les écarts se concentrent sur la gouvernance organisationnelle et les procédures de réponse / reprise.

Exposition financière (FAIR)

Dorian Poncelet

Quantification du risque en euros - référence P90

Avant remédiation

~~~192 000 EUR/an~~

dont 145 k€ (F1 HTTP) + 30 k€ (F8 SECRET\_KEY)



Après corrections (F1 TLS + F8 SECRET\_KEY)

~17 000 EUR/an

-175 000 €/an d'exposition supprimée (F1 + F8)

| Scenario                                   | ALE moyen   | P90         |
|--------------------------------------------|-------------|-------------|
| F1 - HTTP en clair -> CORRIGE (Cloudflare) | 0 EUR       | 0 EUR       |
| F8 - SECRET_KEY -> CORRIGÉ (clé forte)     | 0 EUR       | 0 EUR       |
| RGPD - Fuite BDD (notification CNIL)       | 17 000 EUR  | 33 700 EUR  |
| TOTAL résiduel                             | ~17 000 EUR | ~34 000 EUR |

FAIR : ALE = fréquence x impact, simulé 10 000 fois (Monte Carlo). P90 = la perte annuelle reste sous ce seuil dans 90% des cas - référence pour dimensionner le budget de défense.

# Plan de traitement

Dorian Poncelet

*Proposé par impact financier et facilité de mise en oeuvre*

## **FAIT** Réalisé - durcissement code

- TLS/HTTPS : fait (Cloudflare)
- SECRET\_KEY forte : fait (Secrets Manager)
- En-têtes de sécurité HTTP : fait
- Cookies durcis + politique de mot de passe : fait

## **P2** Court terme (< 1 mois)

- Politique de réponse aux incidents
- Registre des traitements RGPD (Art.30)
- Engagements de confidentialité (NDA)
- Test de restauration RDS snapshot

## **P3** Moyen terme (1-6 mois)

- Séparation dev / test / prod
- Inventaire et classification des actifs
- Plan de continuité documenté (PCA/PRI)

# En résumé



## Une infra de niveau production

77 ressources, 17 modules, déployées en une commande



## Sécurisée par conception

Défense en profondeur 7 couches - pentest puis vulnérabilités corrigées



## Risque maîtrisé et chiffré

Analyse GRC (ISO, NIST, FAIR) et feuille de route priorisée



## Conforme et reproductible

RGPD (Paris), code versionné, reprise via Terraform

**Merci - questions ?**